

Penny Pilot Security Policies

This folder is the security and compliance policy set for Penny Pilot. It exists so that a third party (a banking/data partner like Plaid, an app store reviewer, an investor, or a future customer) can see how the app actually handles data today, not an aspirational enterprise program Penny Pilot doesn't have yet.

Organizational context (read this first): Penny Pilot is a pre-launch personal finance app built and operated by a single founder, Mark Stolte (markstolte02@gmail.com). There is no dedicated security team, CISO, or IT department — the founder holds every role described below. Every policy in this set is written to reflect that reality: roles are named by person, not by title, and any control that would normally be handled by a team (change approval, incident response, offboarding) is written as a solo-operator procedure with a note on what changes once the team grows. Where a control doesn't exist yet, the policy says so explicitly rather than describing it as already in place.

Policies are reviewed whenever the architecture changes materially (e.g., moving from `mock` to `supabase` as the default data source, adding a new vendor, or bringing on a second person) and at minimum annually. Last full review: 2026-07-05.

Index

1. [Information Security Policy](#) — the umbrella policy; scope, ownership, and how the rest of this set fits together.
2. [Access Control Policy](#) — who/what can reach production systems and user data, and how that's enforced.
3. [Password & MFA Policy](#) — end-user auth (delegated to Apple/Google via Supabase) and operator/admin account requirements.
4. [Data Classification & Handling](#) — what data Penny Pilot holds, its sensitivity tier, and handling rules per tier.
5. [Encryption Standards](#) — encryption in transit, at rest, and on-device, including how Plaid access tokens are protected.
6. [Secure Software Development Lifecycle](#) — how code, secrets, and schema changes move from a laptop to production.
7. [Vulnerability Management](#) — how dependency and platform vulnerabilities are tracked and patched.
8. [Incident Response Plan](#) — what happens if something goes wrong, step by step.
9. [Business Continuity & Disaster Recovery](#) — what keeps the app and its data recoverable.
10. [Logging & Monitoring](#) — what's observed today and what isn't yet.
11. [Vendor Risk Management](#) — every third party with access to Penny Pilot data, and why.
12. [Employee Offboarding](#) — not yet applicable (solo team), with the checklist ready for when it is.
13. [Risk Assessment Process](#) — the lightweight, recurring process for reassessing risk as the app grows.

Current architecture, for grounding

- **Client:** Expo/React Native app (`src/`), two data-source modes selected by `EXPO_PUBLIC_DATA_SOURCE`: `mock` (local prototype data, no backend calls) and `supabase` (real backend). Mock is the default while the app is in active development.
- **Backend:** Supabase (Postgres + Auth + Edge Functions). Every user-owned table has Row Level Security scoped to `auth.uid()` (`supabase/migrations/0001_initial_schema.sql`).
- **Bank data:** Plaid, accessed only from Supabase Edge Functions (`supabase/functions/plaid-*`). The mobile app never sees a Plaid secret or a raw Plaid access token — only Supabase-issued, user-scoped responses.
- **Identity:** Supabase Auth, with Apple and Google as the only sign-in providers (`docs/auth-provider-setup.md`). Penny Pilot does not implement its own password store.
- **Manual/local data path:** users can skip bank linking entirely and import a CSV/XLS export from their bank, parsed on-device (`src/services/csv-import.ts`).